REGULATORY FRAMEWORK

# Financial AI Regulatory Compliance Framework

Korea AI Basic Act, EU AI Act, FSS AI RMF Compliance Architecture Design Document

| | |
|---|---|
| Document Type | **Technical Document** |
| Date | **April 2026** |
| Version | **v1.0** |
| Applicable Regulations | **Korea AI Basic Act (Act No. 20676), EU AI Act, GDPR** |

**Executive Summary** — This document systematically maps the domestic and international regulatory requirements that the financial AI recommendation system (PLE-based) must comply with, and defines system-level response architectures for each requirement.

It covers the Korea AI Basic Act (effective 2026.1.22), the Financial Services Commission (FSC) Integrated AI Guidelines 7 Principles, the Financial Supervisory Service (FSS) AI RMF, EU AI Act (Art. 13/14/15), and GDPR Art. 22, including end-to-end compliance architecture spanning audit trails, fairness monitoring, drift surveillance, herding detection, kill switches, opt-out, Human-in-the-Loop, and automated governance report generation.

# Table of Contents


Financial AI Regulatory Environment Overview . . . 4
- Korea AI Basic Act . . . 4
- FSC Integrated AI Guidelines — 7 Principles . . . 5
- FSS AI Risk Management Framework (AI RMF) . . . 5
- Comparison with EU AI Act . . . 6
- Global Regulatory Trends Summary . . . 6

FSS Guidelines Mapping — 7 Principles and System Response . . . 8
- Per-Principle Response Matrix . . . 8
- AI RMF Domain-Level Detailed Mapping . . . 9

EU AI Act Article-Level Mapping . . . 11
- Article 13: Transparency and Information Provision . . . 11
- Article 14: Human Oversight . . . 11
- Article 15: Accuracy, Robustness, and Cybersecurity . . . 12
- GDPR Article 22: Automated Decision-Making . . . 12

Korea AI Basic Act High-Impact AI Classification and Financial Application . . . 14
- High-Impact AI Applicability Assessment . . . 14
- AI Basic Act Key Article Response Status . . . 14
- Regulatory Timeline . . . 15

Compliance Architecture . . . 16
- Overall Structure . . . 16
- Security Controls . . . 17
- 3-Layer Fallback as Regulatory Assurance . . . 17
- Audit Trail . . . 18
- Fairness Monitoring . . . 19
- Drift Surveillance . . . 19
- Herding Detection . . . 19
- Kill Switch . . . 20
- Opt-out and Consent Management . . . 20
- Data Retention Policy . . . 20
- Incident Management . . . 21
- Bedrock Data Protection Architecture . . . 21

On-Premises Regulatory Compliance . . . 23
- Data Protection . . . 23
- Model Configuration . . . 23
- Ops/Audit Agents . . . 23
- Regulatory Compliance Comparison . . . 24
- Model Risk Management (MRM) Framework . . . 24

Operational and Audit Agents . . . 27
- Architecture Overview . . . 27
- OpsAgent (Operational Agent) . . . 27
- AuditAgent (Audit Agent) . . . 27
- Model Selection . . . 28
- Design Principles . . . 28

Airflow DAG Integration . . . 28
Human-in-the-Loop Design . . . 30
Design Principle . . . 30
Per-Channel Human Oversight Framework . . . 30
5 Human Intervention Points . . . 30
Automated Governance Report Generation . . . 32
Report Framework . . . 32
36-Item Regulatory Compliance Auto-Check . . . 32
3-Tier Governance Framework . . . 33
Comprehensive Regulatory Mapping . . . 33
Ops/Audit Agent Integration . . . 34
Temporal Fact Store (Added 2026-04) . . . 34

# Financial AI Regulatory Environment Overview

## Korea AI Basic Act

The **"Framework Act on the Development of Artificial Intelligence and Establishment of Trust"** (Act No. 20676), passed by the National Assembly in December 2024 and promulgated on January 21, 2025, took effect on **January 22, 2026**. It is the first comprehensive AI legislation in the Asia-Pacific region and adopts a Risk-Based Approach.

### Core Legal Structure

**Transparency Obligations** (Art. 31 / Enforcement Decree Art. 22)
Prior notification of AI use, labeling of AI-generated content
Fine up to 30 million KRW for violations

**Safety Assurance** (Art. 32 / Enforcement Decree Art. 23)
Targets ultra-large models with training compute >= $10^{26}$ FLOPs
(Recommendation models are exempt — high-impact AI classification based on **usage domain** applies)

**High-Impact AI Verification** (Art. 33 / Enforcement Decree Art. 24)
Self-review obligation for operators
May request verification from MSIT (response within 30 days)

**High-Impact AI Operator Duties** (Art. 34 / Enforcement Decree Art. 26)
Establish risk management measures, user protection (explainability),
Public disclosure on website, etc.

### High-Impact AI and Finance

The AI Basic Act defines high-impact AI as **"artificial intelligence that significantly affects or may pose risks to human life, physical safety, or fundamental rights"** (Art. 2, Item 4). The Enforcement Decree enumerates 11 domains, explicitly including the **finance (credit/lending)** sector.

| Domain | Application Examples | Finance Relevance |
|---|---|---|
| Healthcare | AI used in medical devices and digital medical devices | Indirect |
| **Finance (Credit/Lending)** | **AI for credit scoring, loan assessment, and personal rights evaluation** | **Direct** |
| Employment | AI for hiring and HR decisions | None |
| Public Services | Eligibility verification, administrative decision-making AI | Indirect |
| Nuclear/Biometric | Nuclear facilities, biometric analysis AI | Indirect |

### Implications for Finance

AI used in **loan assessment and credit scoring** explicitly qualifies as high-impact AI under the law. Even if a financial AI recommendation system does not directly perform lending operations, AI applications in **product recommendation, suitability assessment, and customer classification** may be designated as high-impact AI through future Enforcement Decree amendments or FSC guidelines. Therefore, proactively building a governance framework **at the level of high-impact AI** is a rational strategy.

## FSC Integrated AI Guidelines — 7 Principles

The Financial Services Commission published the **"Revised Financial AI Guidelines"** in alignment with the AI Basic Act. Scheduled for **Q2 2026 implementation** as self-regulatory standards per financial sector, they are organized around 7 principles.

**1. Governance**

Role and responsibility sharing among executives including CEO
AI risk management organization **independently separated** from planning/development

**2. Legality**

Compliance with AI Basic Act, Personal Information Protection Act, Credit Information Act

**3. Auxiliary Nature**

AI is a decision-support tool,
Financial institution bears final responsibility even for external models

**4. Reliability**

Model performance and bias management, explainability (XAI) assurance

**5. Financial Stability**

Third-party dependency, market herding risk assessment
Report to financial authorities on incidents

**6. Good Faith**

**All customer-facing AI services** require prior notification (broader than AI Basic Act)
Conflict of interest prevention, fairness criteria establishment and evaluation

**7. Security**

Data poisoning, model poisoning, prompt injection, etc.
AI-specific threat response framework

Source: Financial Services Commission press release (2025.12)

## FSS AI Risk Management Framework (AI RMF)

The Financial Supervisory Service introduced the **"Financial AI Risk Management Framework (AI RMF)"** in January 2026. Currently, **118 financial institutions operate 653 AI services**, but approximately **85% lack AI ethics principles and risk management standards**.

### AI RMF — 3 Domains

| 1. Governance | 2. Risk Assessment | 3. Risk Control |
|---|---|---|
| Establish AI decision-making body and dedicated organization | Risk identification/measurement -> mitigation -> residual risk | Pre-launch risk mitigation verification |
| Develop risk management regulations | **High/Medium/Low** 3-tier classification | Operational-phase monitoring standards |
| **Independently separated** from planning/development | Quantitative assessment of legality, reliability, good faith, security | Re-classification on risk changes |

## Comparison with EU AI Act

| Category | Korea AI Basic Act | EU AI Act |
|---|---|---|
| Effective Date | 2026. 1. 22. | High-risk AI: 2027. 12. |
| Classification | General/High-impact (2 tiers) | Prohibited/High-risk/Limited/Minimal (4 tiers) |
| Finance Application | Credit scoring/loan assessment explicit | Credit scoring/insurance pricing included |
| Prohibited AI | None | Social scoring, real-time remote biometrics, etc. |
| Obligated Parties | Single operator-centric standard | Entire supply chain: providers, deployers, users |
| Penalties | Fine up to 30M KRW | Up to 7% global revenue or 35M EUR |
| Approach | Promotion-oriented + self-regulation | Safety-oriented + mandatory compliance |
| Impact Assessment | Best-effort obligation | Legally mandatory pre-conformity assessment |

### Comparison Implications

Korea's AI Basic Act has penalties **thousands of times lower** than the EU and relies more on self-regulation, but this is a **soft-landing strategy for the initial implementation period**. The FSC Integrated Guidelines have a broader scope than the AI Basic Act, requiring **prior notification for all customer-facing AI services**. Regulatory intensity is expected to gradually increase through future Enforcement Decree amendments and FSC detailed regulations, making **proactive preparation** advantageous.

## Global Regulatory Trends Summary

Global regulation of financial AI is converging in three directions.

### Transparency & Explainability

Expanding AI disclosure obligations
Requiring decision rationale explanations
Guaranteeing right to refuse automated decisions

### Fairness & Non-discrimination

Quantitative bias measurement by protected attributes
Market herding and conflict of interest prevention
Mandating periodic fairness audits

### Safety & Accountability

Risk-based classification (high-risk AI)
Mandatory emergency shutdown mechanisms
Audit trail retention obligations

# FSS Guidelines Mapping — 7 Principles and System Response

Mapping the current response status of the PLE-based financial AI recommendation system against the FSC Integrated AI Guidelines 7 Principles and FSS AI RMF requirements.

## Per-Principle Response Matrix

| 7 Principles | System Response | Level |
|---|---|---|
| 1. Governance<br>(AI RMF G-1~G-6) | 3-tier governance framework design complete<br>(Decision Committee -> Operations Team -> Internal Audit)<br>Monthly/quarterly governance report auto-generation<br>36-item regulatory compliance registry auto-check | ◯ |
| 2. Legality<br>(AI RMF R-2) | Eligibility/suitability auto-verification (Financial Consumer Protection Act Art. 17/18)<br>PII de-identification (SHA-256 + domain-specific salt)<br>Credit Information Act retention compliance (5 years) | ● |
| 3. Auxiliary Nature<br>(AI RMF C-4) | Human oversight + Kill Switch 3-tier emergency shutdown<br>Human reprocessing routing (P1/P2/P3 SLA)<br>Right to refuse AI automated decisions + alternative pathway | ● |
| 4. Reliability<br>(AI RMF R-3, C-2~C-3) | Champion-Challenger automatic model competition<br>PSI-based drift detection + 3-consecutive-day retraining trigger<br>IG-based per-feature attribution + natural language recommendation rationale | ● |
| 5. Financial Stability<br>(AI RMF R-3~R-4) | HHI/Gini/Entropy herding detection<br>DI/SPD/EOD fairness 3-metric auto-measurement<br>5 protected attributes (age, gender, region, income, lifecycle) | ● |
| 6. Good Faith<br>(AI RMF R-4) | AI disclosure centralized management + per-segment notification separation<br>Conflict of interest prevention (auto-penalty when high-fee products exceed 40%)<br>Opt-out registration/withdrawal/confirmation full lifecycle management | ● |
| 7. Security<br>(AI RMF R-5) | Prompt injection defense 8 patterns (4 Korean + 4 English)<br>Model integrity SHA-256 hash verification<br>HMAC + hash chain audit log immutability | ● |

● Met ◯ Partially met (organizational decision needed)

# AI RMF Domain-Level Detailed Mapping

### Domain 1: Governance (G-1 G-6)

| No. | RMF Requirement | Current Response Status | Level |
|---|---|---|---|
| G-1 | Establish AI top decision-making body | 3-tier governance framework designed; formal committee establishment needed | △ |
| G-2 | Independent AI risk management org | Operations team handles both dev and ops; independent function separation needed | △ |
| G-3 | Establish AI risk management regulations | FD-TVS, drift detection logic exists; internal regulation documentation needed | ◯ |
| G-4 | Establish and publish AI ethics principles | Not yet established — enterprise AI ethics document needed | △ |
| G-5 | High-impact AI pre-approval process | Pre-launch approval process formalization needed | △ |
| G-6 | Periodic AI utilization reporting | Monthly report auto-generation complete; reporting line formalization needed | ◯ |

### Domain 2: Risk Assessment (R-1 R-6)

| No. | RMF Requirement | Current Response Status | Level |
|---|---|---|---|
| R-1 | Risk classification per AI service | Self-assessment of high-impact AI applicability complete; formal classification system needed | ◯ |
| R-2 | Legality assessment | Eligibility auto-verification + de-identification + retention compliance | ● |
| R-3 | Reliability assessment | Champion-Challenger + drift detection + fairness auto-measurement | ● |
| R-4 | Good faith assessment | 5 protected attributes DI/SPD/EOD + conflict prevention + Parquet archiving | ● |
| R-5 | Security assessment | Local AI + SHA-256 encryption + prompt injection defense + integrity verification | ● |
| R-6 | Residual risk assessment | FD-TVS risk penalty auto-block; Risk Appetite documentation needed | ◯ |

### Domain 3: Risk Control (C-1 C-6)

| No. | RMF Requirement | Current Response Status | Level |
|---|---|---|---|
| C-1 | Pre-launch risk mitigation verification | Eligibility rules + fatigue filtering + A/B testing framework | ● |
| C-2 | Operational monitoring standards | Drift auto-detection + performance dashboard + anomaly alerts | ● |

| | | | |
|---|---|---|---|
| C-3 | Periodic model evaluation/ retraining | Weekly/monthly auto-retraining + Champion-Challenger + MLflow versioning | ● |
| C-4 | Human oversight framework | Kill Switch 3-tier + human reprocessing routing + opt-out | ● |
| C-5 | Emergency shutdown mechanism | GLOBAL/PER_TASK/PER_CLUSTER 3-tier kill switch | ● |
| C-6 | Audit trail assurance | HMAC hash chain + S3 Object Lock + 7 audit tables | ● |

# EU AI Act Article-Level Mapping

The EU AI Act is likely to classify financial AI recommendation systems as **high-risk AI** (Annex III, 5(b): credit scoring/insurance pricing). The following maps system responses to key articles.

## Article 13: Transparency and Information Provision

### Art. 13 Requirements and System Response

| Art. 13 Requirement | System Response |
|---|---|
| Notify use of high-risk AI | AI disclosure centralized management + per-segment notification separation<br>All recommendation outputs automatically include AI usage labeling |
| Explain system operation | 2-Layer recommendation rationale (L1 Template + L2 LLM)<br>3-Agent pipeline (Feature Selector → Reason Generator → Safety Gate) |
| Disclose input data specification | Feature schema auto-documentation ( 349D input / 403D post-Phase-0 current / 734D full-bank design)<br>Training data source, scope, and pseudonymization status recorded |
| Disclose performance level | Model card auto-generation (architecture, performance, feature importance)<br>Per-task independent metric tracking (13 tasks: avg_auc binary / avg_f1_macro multiclass / avg_mae regression) |
| Log generation obligation | HMAC + hash chain audit log (S3 Object Lock WORM)<br>Full recommendation history Parquet archiving |

## Article 14: Human Oversight

### Art. 14 Requirements and System Response

| Art. 14 Requirement | System Response |
|---|---|
| Provide interface for humans to oversee AI system | Offline: Staff screen shows recommendation list + rationale; final recommendation is staff judgment<br>Online: AI operations team directly controls recommendation direction, targets, and exclusion lists |
| Ensure ability to intervene and halt system | Kill Switch 3-tier (GLOBAL/PER_TASK/PER_CLUSTER)<br>Auto-switch to conservative mode on drift detection |

| | |
|---|---|
| Right to refuse automated decisions + alternative pathway | Opt-out registration/withdrawal/confirmation + 3-tier human reprocessing routing<br>(P1 urgent 1h / P2 4h / P3 24h SLA) |

## Article 15: Accuracy, Robustness, and Cybersecurity

### Art. 15 Requirements and System Response

| Art. 15 Requirement | System Response |
|---|---|
| Achieve and maintain appropriate accuracy levels | Champion-Challenger automatic model competition<br>PSI-based drift detection + auto-retraining on 3 consecutive critical days |
| Robustness against errors and faults | Ablation-based per-component contribution quantification<br>Distilled LGBM fallback (auto-switch on teacher performance anomaly) |
| Cybersecurity threat response | Prompt injection defense 8 patterns (5 severity levels)<br>Model integrity SHA-256 verification<br>Input validation (format + size limits) |
| Bias prevention measures | DI/SPD/EOD 3-metric fairness auto-measurement<br>5 protected attributes continuous monitoring<br>Auto-incident creation on threshold violation |

## GDPR Article 22: Automated Decision-Making

### GDPR Art. 22 and Related Provisions Response

GDPR Art. 22 grants data subjects the right to refuse **"decisions based solely on automated processing, including profiling."** Korea's Personal Information Protection Act Art. 37-2 guarantees the same right.

| GDPR Requirement | System Response |
|---|---|
| Right to refuse automated decisions (Art. 22(1)) | Opt-out registration/withdrawal/confirmation full lifecycle management<br>Immediate switch to human alternative pathway upon refusal |
| Right to request human intervention (Art. 22(3)) | Human reprocessing routing (auto-counselor switch for 7 reason categories)<br>P1/P2/P3 SLA management |
| Profiling information provision (Art. 13(2)(f)) | Decision criteria auto-documentation (30+ filter reasons with explanations)<br>Feature reverse mapping + per-task interpretation |

| | |
|---|---|
| Right to erasure (Art. 17) | 30-day PII retention policy + encrypted deletion<br>S3 Lifecycle auto-applied |
| Data subject rights audit (Art. 30) | Among 7 audit tables: profiling_audit, opt_out_audit, consent_audit<br>DynamoDB serverless management + TTL auto-cleanup |

# Korea AI Basic Act High-Impact AI Classification and Financial Application

## High-Impact AI Applicability Assessment

Under current law, financial product recommendation systems are **not subject to explicit high-impact AI classification as they do not constitute loan assessment**. However, expanded designation is possible under the following scenarios.

| Scenario | Likelihood | Basis |
|---|---|---|
| Enforcement Decree amendment to include all financial product recommendations | Medium | EU AI Act already covers this scope |
| Customer classification/segmentation interpreted as rights evaluation | Low-Medium | Similar structure to investment suitability assessment |
| Business expansion to insurance product recommendations | High | Insurance pricing is EU high-risk and domestic high-impact in both frameworks |
| Discriminatory benefits based on churn prediction | Medium | Directly linked to fairness issues |
| FSC guidelines separately regulating recommendation AI | Medium-High | Must monitor trends after integrated guidelines take effect |

> **Response Strategy**
>
> While not currently subject to direct high-impact AI classification, considering the **direction of the regulatory environment**, proactively building a governance framework at **virtually the same level as high-impact AI** is a rational strategy. This not only minimizes regulatory risk but also provides an immediately deployable foundation for future business expansion (insurance, fund recommendations, etc.).

## AI Basic Act Key Article Response Status

| Requirement | Basis | Current Response | Level |
|---|---|---|---|
| Prior notification of AI use | Art. 31 | AI disclosure centralized management, per-segment notification separation<br>Automatically included in all recommendation outputs | ● |
| Labeling of AI-generated content | Art. 31 | AI generation label auto-applied to recommendation rationale text | ● |

| | | | |
|---|---|---|---|
| Risk management measures implementation | Art. 32 | FD-TVS + Kill Switch (3-tier) + eligibility/suitability verification<br>1. drift detection | ● |
| High-impact AI applicability check | Art. 33 | Scenario-based applicability analysis complete | ● |
| Risk management and user protection | Art. 34 | Safety/trust document + model card auto-generation<br>3-stage recommendation rationale pipeline | ● |
| Impact assessment execution | Art. 35 | System documentation complete; periodic execution process needs organizational establishment | ◯ |
| Right to refuse automated decisions | PIPA Art. 37-2 | Opt-out + 3-tier human reprocessing routing | ● |
| Governance framework establishment | 7 Principles | 3-tier framework designed; formal committee establishment needed | ◯ |

● Met ◯ Partially met △ Insufficient

# Regulatory Timeline

## Key Regulatory Dates

| Date | Event |
|---|---|
| 2025. 1. 21 | AI Basic Act promulgation |
| 2025. 08 | AI Basic Act Enforcement Decree pre-announcement |
| 2025. 12. 22 | FSC Integrated AI Guidelines (draft) release |
| 2026. 1. 15 | FSS AI RMF introduction |
| **2026. 01. 22** | **AI Basic Act effective** |
| 2026 Q1 | Integrated Guidelines and AI RMF finalized and effective |
| 2027. 01 (est.) | AI Basic Act fines enforcement begins |
| 2027. 12 | EU AI Act high-risk AI provisions fully applicable |

# Compliance Architecture

## Overall Structure

The regulatory compliance infrastructure is organized in 3 layers.

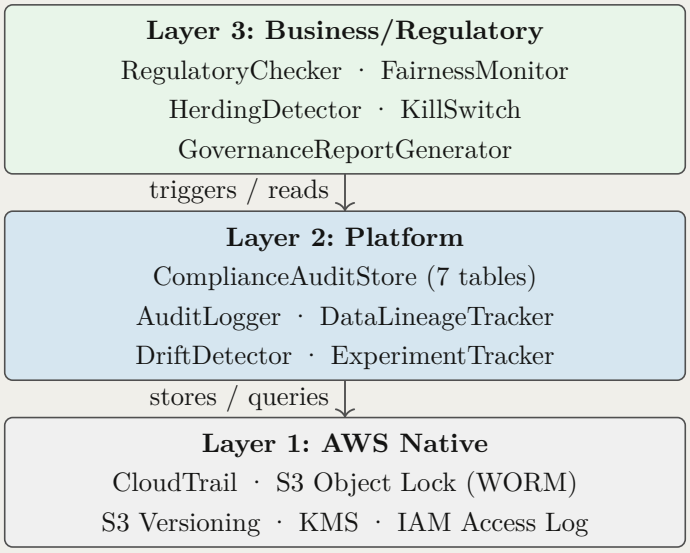


Figure 1: 3-layer compliance architecture. Layer 3 enforces business rules; Layer 2 manages platform-level audit state; Layer 1 provides immutable AWS-native guarantees.

### Layer 1: AWS Native (Automatic, No Additional Cost)

- **CloudTrail** -> All AWS API calls automatically recorded
- **S3 Versioning** -> Data/model change history preserved
- **S3 Object Lock** -> Audit log immutability (WORM)
- **KMS** -> Encryption key management + key usage audit
- **IAM Access Log** -> Resource access audit

### Layer 2: Platform Level (Semi-automatic)

- **ComplianceAuditStore** -> 7 audit tables (DynamoDB)
- **AuditLogger** -> HMAC + hash chain (S3 + DynamoDB)
- **DataLineageTracker** -> Feature-to-source tracing (S3 metadata)
- **ExperimentTracker** -> Experiment metrics (SageMaker Experiments)
- **DriftDetector** -> PSI monitoring (SageMaker Model Monitor)

### Layer 3: Business/Regulatory Level (Explicit)

- **RegulatoryComplianceChecker** -> 36-item auto-check

- **FairnessMonitor** -> DI/SPD/EOD protected attribute monitoring (batch evaluation per cycle)
- **HerdingDetector** -> Systemic risk herding detection
- **IncidentReporter** -> Auto-report by severity
- **GovernanceReportGenerator** -> Monthly/quarterly governance reports (auto-generated per cycle)
- **KillSwitch** -> Emergency model deactivation
- **ComplianceAuditStore** -> Logs every prediction with full compliance context
- **ConsentManager** -> Marketing consent lifecycle (grant/revoke/renew/verify)
- **AIOptOut** -> AI decision refusal registration, withdrawal, confirmation
- **ProfilingRights** -> Data subject rights exercise (access/correction/deletion/portability)

## Security Controls

### PII Protection and LLM Security

**PII Masking in Serving:** Customer PII (name, account number, resident registration number) is masked before entering the recommendation reason generation pipeline. Only anonymized tokens are passed to the LLM layer, structurally preventing PII leakage to external model providers.

**PromptSanitizer for LLM Calls:** All prompts passed to Bedrock (Claude Haiku) are pre-processed by `PromptSanitizer`, which strips 8 injection patterns (4 Korean + 4 English) and validates prompt structure before the API call. This satisfies FSC Principle 7 (Security) and AI Basic Act Art. 34 (risk management).

**Structural separation:** The compliance module (ConsentManager, AIOptOut, RegulatoryChecker, ProfilingRights) operates independently from the scoring and reason-generation path. Compliance checks are enforced as pre-flight gates — a prediction is only served if all compliance conditions are satisfied.

## 3-Layer Fallback as Regulatory Assurance

The 3-layer fallback architecture ensures that service never completely stops — a critical regulatory requirement under FSS AI RMF C-5 (emergency shutdown with fallback).

| Layer | Mechanism | When Active |
|---|---|---|
| Layer 1 (Primary) | Distilled LGBM Student via Lambda + FallbackRouter | Normal operation |
| Layer 2 (Failover) | Direct PLE Teacher inference (SageMaker Endpoint) | Student degraded or unavailable |
| Layer 3 (Safety Net) | Rule-based engine: 13-task rules + Financial DNA routing | Both model layers unavailable |

**Regulatory significance:** Even under CRITICAL kill-switch activation, Layer 3 guarantees customers receive rule-based product guidance — preventing a complete service blackout. All three layers produce `contributing_features` for explanation compliance.

> **CloudFormation DynamoDB Compliance Tables**
>
> The following DynamoDB tables are provisioned via CloudFormation for compliance state management:
> - `consent-store`: Marketing consent records (grant/revoke/renew/channel)
> - `opt-out-store`: AI decision refusal history per customer
> - `profiling-rights-store`: Data subject rights exercise records
> - `audit-store`: Per-prediction compliance audit log (ComplianceAuditStore)
>
> All tables use TTL auto-cleanup aligned with the 7-year retention policy.

## Audit Trail

### Immutable Logs — HMAC + Hash Chain

Each audit log entry is signed with HMAC-SHA256, and consecutive entries are linked via SHA256 hash chain (prev_hash) to prevent tampering.

| On-Prem | AWS |
|---|---|
| Local JSONL + HMAC + hash chain | S3 Object Lock (WORM) + HMAC + hash chain |

**AWS Reinforcement:**
- S3 Object Lock: Physical deletion blocked at AWS level (even administrators cannot delete)
- KMS encryption: Audit logs themselves are encrypted
- CloudTrail: Access to audit logs is also audited (meta-audit)

### 7 Regulatory Audit Tables

DynamoDB-based serverless management (auto-scaling, per-item TTL):

| Table | Purpose | Retention |
|---|---|---|
| ks_audit | Kill switch activation/deactivation history | 7 years |
| consent_audit | Marketing consent change history (grant/revoke/renew) | 7 years |
| profiling_audit | Data subject rights exercise (access/correction/deletion/restriction/portability) | 7 years |
| opt_out_audit | AI decision refusal history | 7 years |
| incident_audit | Regulatory incidents (by severity) | 7 years |
| distillation_audit | Teacher-student model performance gap | 3 years |
| embedding_audit | Embedding quality metrics | 3 years |

## Fairness Monitoring

3 fairness metrics are continuously monitored across 5 protected attributes.

Note on income: **income** is an input feature and a protected attribute monitored for fairness bias. It is *not* a model task. The deterministic bucket derivation `income_tier` was removed from tasks (13-task set, v14 → v13 reduction) due to leakage — the model could trivially reconstruct the label from the feature. Similarly, `tenure_stage`, `spend_level`, and `engagement_score` were removed as deterministic transformations of inputs. The income *feature* itself is retained and monitored.

### Protected Attributes

- **Age group**: youth / middle / pre_senior / senior
- **Gender**: M / F / unspecified
- **Region type**: metropolitan / urban / rural
- **Income quintile**: low / middle / high (feature, not task)
- **Lifecycle**: 6 classes

### Thresholds and Actions

- **DI (Disparate Impact)**: 0.8 1.25
- **SPD (Statistical Parity Difference)**: |SPD| <= 0.1
- **EOD (Equal Opportunity Difference)**: |EOD| <= 0.1

DI < 0.6 -> CRITICAL incident
DI < 0.8 -> MAJOR incident
|SPD| > 0.1 -> MINOR incident

## Drift Surveillance

Combines SageMaker Model Monitor (default) + custom PSI (extended).

| Metric | Threshold | Auto Action |
|---|---|---|
| PSI (warning) | 0.1 | Warning logging |
| PSI (critical) | 0.25 | Alert responsible party |
| 3 consecutive critical days | – | Auto-retraining trigger (Step Functions) |

**Per-feature individual PSI is tracked**, enabling early detection of sudden changes in specific features even when the overall distribution appears stable.

## Herding Detection

Prevents **systemic risk** from excessive recommendation concentration on the same products.

| Metric | Description | Severity Classification |
|---|---|---|
| HHI | Herfindahl-Hirschman Index — market concentration | none -> low -> medium |
| Gini coefficient | Recommendation inequality measurement | -> high -> critical |
| Entropy | Recommendation diversity measurement | |

| | | |
|---|---|---|
| Herding rate | Proportion of most-recommended product | Kill switch review on critical |

## Kill Switch

3-tier emergency model deactivation system.

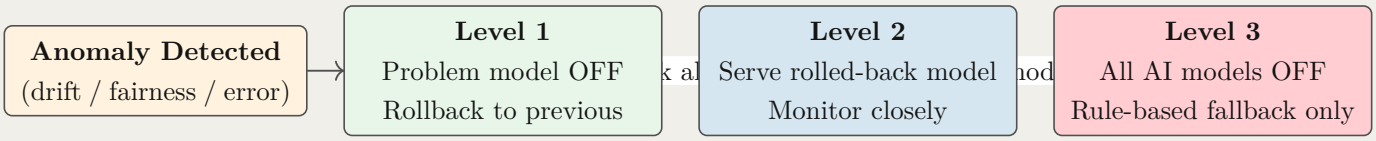


Figure 2: Kill switch escalation: 3-level cascade with automatic fallback. Service never fully stops.

### Kill Switch Structure

**GLOBAL**
Full model deactivation
State stored in DynamoDB
Checked on every request

**PER_TASK**
Specific task only deactivated
(e.g., click, purchase)
Only that task falls back

**PER_CLUSTER**
Specific customer segment only
(e.g., cluster_5)
Only that cluster falls back

**Fallback strategies**: Rule-based recommendations / previous model rollback / recommendation deactivation (choose one)

## Opt-out and Consent Management

| Feature | Description |
|---|---|
| AI decision refusal registration | Opt-out registration -> immediate switch to human alternative pathway |
| Refusal withdrawal | Previous opt-out withdrawn -> AI recommendation reactivated |
| Marketing consent management | Grant/revoke/renew history tracking, per-channel and per-purpose opt-in verification |
| Nighttime SMS blocking | Auto-filtering by marketing consent status + time zone |
| Audit trail | All consent changes and refusal history recorded in consent_audit, opt_out_audit |

## Data Retention Policy

Automatically applied via S3 Lifecycle Rules.

| Category | Retention | Action | Regulatory Basis |
|---|---|---|---|
| Raw Data | 30 days | Delete | GDPR minimization principle |
| Processed Features | 90 days | Glacier archive | Retraining support |

| | | | |
|---|---|---|---|
| Training Data | 365 days | Glacier archive | Reproducibility assurance |
| Model Checkpoints | 365 days | Retain | Rollback support |
| Inference Results | 90 days | Delete | Dispute response |
| Audit Logs | 2,555 days (7 years) | Immutable retention (WORM) | Financial regulation 7-year retention |
| PII Data | 30 days | Encrypted deletion | GDPR Art. 17 right to erasure |

## Incident Management

Automated classification and response system by severity.

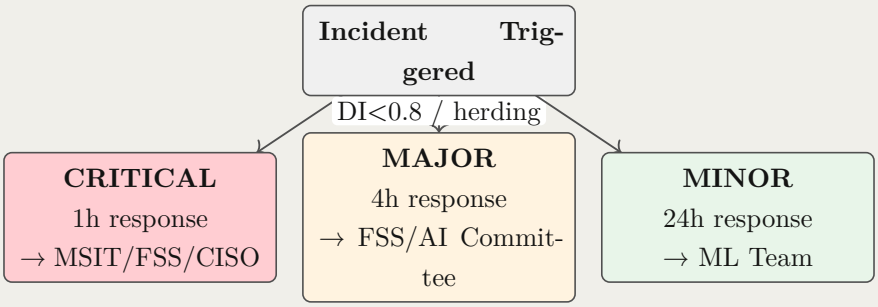


Figure 3: Incident severity classification with differentiated response SLAs and escalation targets.

| Severity | Response Time | Trigger | Report To |
|---|---|---|---|
| CRITICAL | 1 hour | Kill switch activation, DI<0.6, security breach | MSIT/FSS/CISO |
| MAJOR | 4 hours | DI<0.8, herding critical, model rollback | FSS/AI Committee |
| MINOR | 24 hours | Drift warning, quality degradation, herding high | ML Team |

## Bedrock Data Protection Architecture

The most critical regulatory issue when leveraging LLMs in financial AI systems is the prevention of customer data leakage. Amazon Bedrock addresses this through five structural safeguards:

| Safeguard | Details |
|---|---|
| No Data Training | Input/output data is never transmitted to model providers (Anthropic, Upstage, Meta, etc.) and is never used for model retraining (including fine-tuning). AWS guarantees this contractually in its Terms of Service. |
| Transit Encryption | TLS 1.2+ encryption protects data in transit. |
| VPC PrivateLink | Bedrock API is invoked through VPC-internal endpoints without traversing the public internet. Customer data is never exposed to public networks. |
| In-Region Processing | All inference is processed in the ap-northeast-2 (Seoul) Region. Customer data never leaves Korea. |

| | |
|---|---|
| CloudTrail Audit | Every Bedrock API call (InvokeModel, Converse, etc.) is automatically recorded in CloudTrail. Complete audit trail of who called which model when. |

### Regulatory Mapping

| Regulation | Requirement | Bedrock Compliance |
|---|---|---|
| PIPA (Korea) | Third-party provision vs. delegated processing | Bedrock constitutes delegated processing within AWS infrastructure. Data is not transmitted to model providers, thus not third-party provision. |
| PIPA (Korea) | Cross-border transfer restriction | In-region processing in ap-northeast-2. No cross-border transfer occurs. |
| Korean FSS AI Guidelines | Data governance | CloudTrail audit logs + VPC isolation + transit encryption enable complete data flow tracking. |
| EU AI Act Art.10 | Data governance | No-training-use guarantee. Inference data processing location documented. |
| AI Basic Act (Korea) | High-impact AI data management | HMAC audit logs and CloudTrail dual-recording prove data processing history. |

### Data Flow Diagram

Data flow during recommendation reason generation and agent diagnostics:

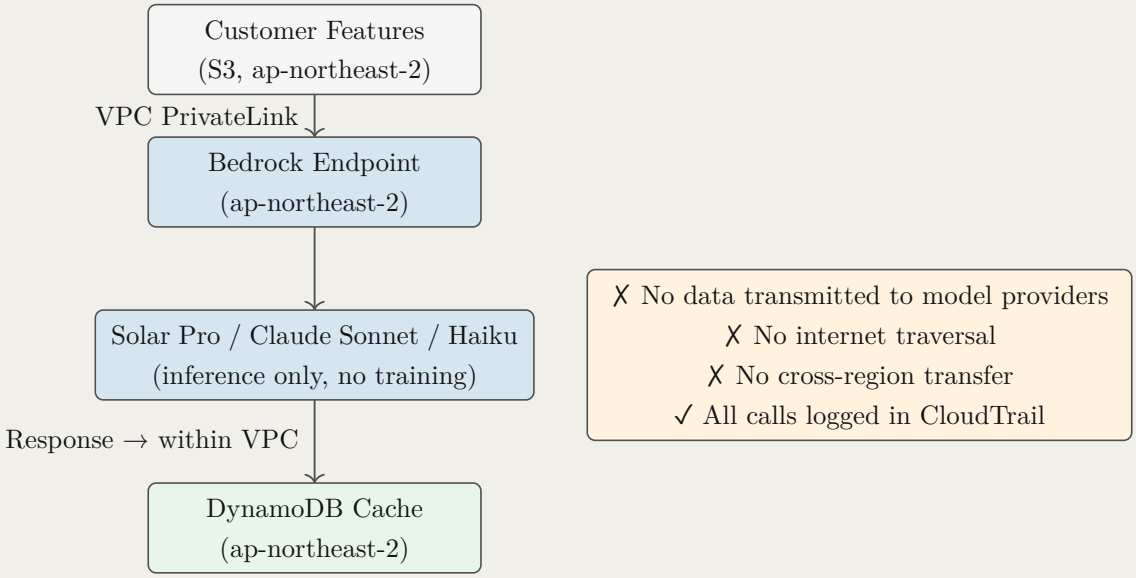


Figure 4: AWS Bedrock data flow: processed via VPC PrivateLink with no cross-region data transfer.

# On-Premises Regulatory Compliance

Air-gapped on-premises environments are **structurally stronger** than cloud deployments from a data protection perspective, as external network access is architecturally impossible.

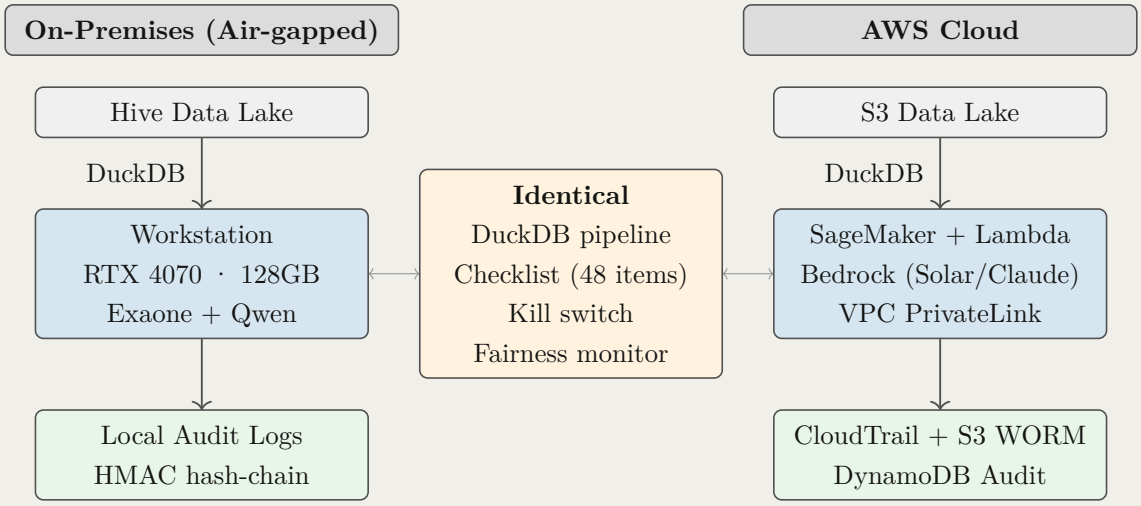


Figure 5: On-premises vs AWS: identical DuckDB pipeline and compliance framework, different infrastructure layers.

## Data Protection

| Item | On-Premises | AWS (Bedrock) |
|---|---|---|
| External data transfer | **Impossible** — air-gapped | In-region via VPC PrivateLink |
| Model provider data access | **N/A** — local open-source models | Contractually prohibited by Bedrock ToS |
| Audit trail | Local HMAC hash-chain (JSONL) | S3 Object Lock + CloudTrail |
| Cross-border transfer | **Cannot occur** | Processed within ap-northeast-2 |

## Model Configuration

All on-premises models are open-source:

| Purpose | Model | License & Notes |
|---|---|---|
| Reason generation/critique | Exaone 3.5 7.8B | Apache 2.0 (LG AI Research). Korean-specialized. |
| Agent consensus | Qwen 2.5 14B Q4 | Apache 2.0 (Alibaba). Logical reasoning. |
| Embeddings | all-MiniLM-L6-v2 | Apache 2.0 (sentence-transformers). |

Sequential loading on RTX 4070 (12GB VRAM). Zero vendor lock-in; model replacement requires only config changes.

## Ops/Audit Agents

On-premises agents use the **same rule engine, checklist, and tool catalog** as AWS. Differences:

| Feature | On-Premises | AWS |
|---|---|---|
| Checklist evaluation | Identical (48 items) | Identical |
| Consensus mechanism | 2-Round hybrid (Qwen 14B × 5+2) | Independent voting (Sonnet × 3) |
| Minority report | Identical — locked at Round 1 | Identical |
| Operator dialog | Not available — structured reports only | Sonnet Tool Use conversation |
| Case store | Identical (LanceDB) | Identical |
| Notifications | Email/Slack | SNS + Slack |

## Regulatory Compliance Comparison

| Requirement | On-Premises | AWS |
|---|---|---|
| PIPA cross-border transfer | Impossible (air-gapped) | In-region processing |
| FSS data governance | Local HMAC audit logs | CloudTrail + S3 Object Lock |
| EU AI Act human oversight | Agent recommendation + human decision (same) | Same + dialog interface |
| AI Basic Act kill switch | Local kill switch (same) | DynamoDB kill switch |
| Explainability | IG-based reasons + Exaone rewrite | IG-based reasons + Solar rewrite |

On-premises lacks conversational agent capabilities but offers structurally perfect data protection. From a regulatory perspective, "customer data never leaves the premises" is the strongest possible safeguard.

## Model Risk Management (MRM) Framework

Full-lifecycle model governance aligned with **SR 11-7** (Federal Reserve/OCC), **EBA ML Guidelines**, and **NIST AI RMF 1.0**.

### MRM Lifecycle

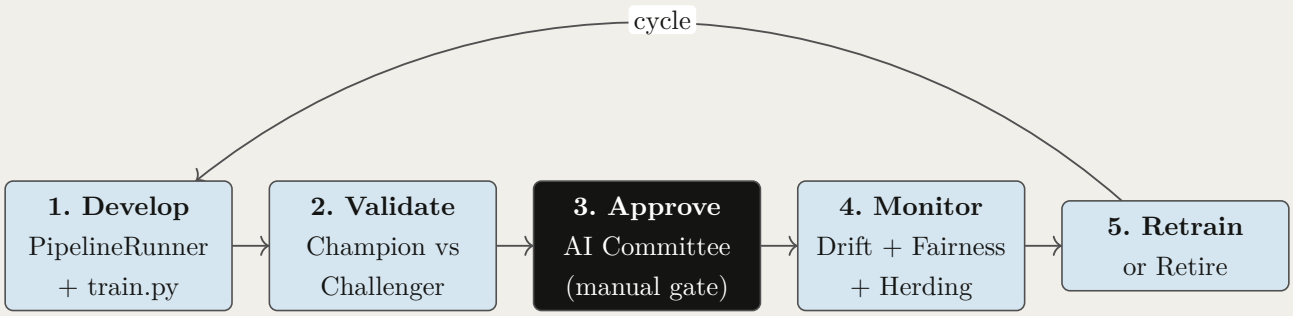


Figure 6: MRM lifecycle: 5-stage cycle aligned with SR 11-7, NIST AI RMF, and FSS AI RMF. Stage 3 (Approve) is always manual.

> **Development → Validation → Approval → Monitoring → Retrain / Retire**
>
> | Stage | Activity | System Component |
> |---|---|---|
> | Development | Feature engineering, model training, offline evaluation | PipelineRunner (Phase 0) + train.py (Phase 1) |

| | | |
|---|---|---|
| Validation | Champion-Challenger comparison, ablation, fairness audit | ModelCompetitionManager + FairnessMonitor |
| Approval | Manual review gate — `auto_promote = false` | AI Committee sign-off (Human-in-the-Loop) |
| Monitoring | Drift, performance, fairness, herding — continuous | DriftDetector + PerformanceMonitor + FairnessMonitor |
| Retrain / Retire | Triggered retrain or model decommission | ConsecutiveDriftTracker → dag_monthly_retrain |

### Model Inventory

#### Model Registry

Every model version is recorded in `ModelCompetitionManager.model_registry` with:

- **Model ID, version, training date, dataset snapshot hash**
- **Architecture config** (expert count, task groups, adaTT strengths)
- **Validation metrics** (per-task AUC/F1/MAPE, calibration, fairness DI/SPD/EOD)
- **Approval status** (pending / approved / rejected / retired)
- **Lineage** — which champion it replaced and why

### Independent Validation (Champion-Challenger)

#### SR 11-7 Pillar 2 — Independent Model Validation

**Gate policy**: `auto_promote = false` — no model enters production without explicit human approval.

**Comparison criteria**:

1. Per-task AUC / F1 / MAPE (absolute performance)
2. Paired $t$-test across temporal folds (statistical significance)
3. Calibration: predicted probability vs. observed frequency
4. Fairness: Disparate Impact (DI $> 0.8$), SPD, EOD
5. Inference latency and cost efficiency

**Decision flow**: Challenger trained → metrics collected → report generated → AI Committee reviews → promote / reject / request re-experiment.

### Continuous Monitoring → Retrain Trigger

| Monitor | Trigger Condition | Action |
|---|---|---|
| DriftDetector (PSI) | Feature or prediction PSI $> 0.25$ | Alert (Orange) |
| ConsecutiveDriftTracker | 3 consecutive days of critical drift | Auto-trigger `dag_monthly_retrain` |
| FairnessMonitor | DI $< 0.8$ or SPD/EOD threshold breach | Alert → AI Committee review |

| | | |
|---|---|---|
| PerformanceMonitor | Task AUC below Yellow threshold | Alert → retrain evaluation |

After retraining completes, `dag_champion_challenger` is invoked automatically: the new model becomes the challenger and must pass the validation gate described above before promotion.

**Emergency Response (Kill Switch)**

When monitoring detects a critical failure, the 3-tier Kill Switch provides immediate response:

1. **Deactivate** — model serving is halted (global / per-task / per-cluster granularity)
2. **Rollback** — previous approved model version is restored from the registry
3. **Fallback** — rule-based recommendation engine takes over until a validated model is re-deployed

All kill-switch activations are logged as CRITICAL incidents and reported to MSIT/FSS/CISO within 1 hour per the Incident Management protocol above.

# Operational and Audit Agents

## Architecture Overview

The serving agents (L1 Rule / L2a Retrieval / L2b Generation) reside on the real-time recommendation path. The **OpsAgent** and **AuditAgent** described here are fully separate **batch-only** agents that share no state with the serving path. They execute exclusively as downstream tasks within Airflow DAGs. This separation ensures regulatory surveillance functions do not impact real-time serving SLAs.

## OpsAgent (Operational Agent)

### Trigger and Input

**Trigger**: `dag_drift_monitoring` completion, training Job completion event
**Input data**:
- `eval_metrics.json`: per-task AUC/F1/MAPE, calibration metrics
- Training logs: per-task loss trajectory, gradient norm history
- Gate entropy: expert routing skew (MoE gate softmax distribution)
- PSI drift reports: feature/prediction/label distribution changes

**Processing pipeline**: JSON parsing → anomaly detection rules (threshold-based pre-filtering) → on anomaly detection, forward structured prompt to LLM.

### Prompt example

"Analyze the following eval_metrics.json and gate entropy. Report (1) tasks with degraded performance, (2) gate skew (experts with entropy $< 0.3$), (3) features exceeding PSI threshold, (4) recommended actions in structured format."

**Output**: Model health report (Markdown) — stored at S3 `governance/ops_reports/`. On anomaly detection, alerts are sent via Slack channel and email.

## AuditAgent (Audit Agent)

### Trigger and Input

**Trigger**: `dag_fairness_monitoring` completion, quarterly governance cycle (`dag_governance_quarterly`)
**Input data**:
- FairnessMonitor report: DI/SPD/EOD (5 protected attributes × per-task)
- Audit trail integrity verification: HMAC hash chain validation status
- Opt-out statistics: request count, processing rate, avg. processing time by period
- Governance checklist: 36-item auto-check results

**Processing pipeline**: automated comparison against regulatory thresholds (DI $\geq 0.8$, $|\text{SPD}| \leq 0.1$, $|\text{EOD}| \leq 0.1$) → violation extraction → request LLM to summarize violations and recommend actions.

> **Prompt example**
>
> "Compare the following fairness metrics against FSS thresholds (DI$\geq$ 0.8, |SPD|$\leq$ 0.1, |EOD|$\leq$ 0.1). Report (1) violations (protected attribute, task, metric value), (2) severity (P1/P2/P3), (3) recommended actions."

**Output**: Regulatory compliance report (Markdown) — stored at S3 `governance/audit_reports/`. Alerts dispatched by priority: P1 (immediate escalation), P2 (review within 24h), P3 (included in quarterly report).

## Model Selection

| Environment | Model | Rationale |
|---|---|---|
| Air-gapped (on-prem) | Exaone 3.5 7.8B (reason gen.) + Qwen 2.5 14B Q4 (agent consensus) | Apache 2.0 open-source. Sequential loading on RTX 4070. |
| Cloud (AWS) | Claude Haiku 4.5 API | Cost-efficient ($0.25/1M input), reliable structured output |

**Cost estimate**: 1–2 calls per batch yields approximately $0.01/day. Input consists of JSON metrics (a few KB) + prompt, so token consumption is minimal.

## Design Principles

### Automation scope

**Batch-only**: does not intervene in real-time serving path
**Structured judgments**: threshold comparison, trend analysis, violation classification are handled by the agent
**Unstructured judgments**: suspected data contamination, business context shifts, regulatory interpretation are reserved for humans

### Audit artifact guarantees

**HMAC signing**: agent output itself is an audit artifact — HMAC-signed and immutably stored upon generation
**Hash chain**: tamper-proof guarantee via hash chain linked to prior reports
**Human review**: "check when you arrive" model — agent organizes, humans review at their own pace

## Airflow DAG Integration

| DAG | Agent task | Cadence |
|---|---|---|
| `dag_drift_monitoring` | After drift detection → `ops_agent_report` task appended | Daily |
| `dag_fairness_monitoring` | After fairness measurement → `audit_agent_report` task appended | Daily |

| | | |
|---|---|---|
| `dag_governance_quarterly` | After 36-item check → `audit_agent_quarterly` report | Quarterly |
| Training Job completion callback | `ops_agent_training_report` — training metric analysis | Event-driven |

# Human-in-the-Loop Design

The FSS ultimately requires **human-involved decision-making**. EU AI Act Art. 14 also mandates the same principle. Even when everything is automated, final review is performed by humans.

## Design Principle

> **AI is the tool; final decision authority rests with humans**
>
> The PLE-based recommendation system is not "replacing humans" but a tool that "supports human decision-making." This principle is embedded throughout the system architecture.

## Per-Channel Human Oversight Framework

| Channel | Human Oversight Method |
|---|---|
| Offline (Branch) | AI **provides** recommendation list + rationale on staff screen<br>Final recommendation decision is made by **staff judgment**<br>Staff reviews rationale and recommends based on customer situation |
| Online (App/Web) | AI auto-serves recommendation list<br>AI operations team **directly controls** recommendation direction, targets, and exclusion lists<br>Immediate shutdown via kill switch in emergencies |

## 5 Human Intervention Points

### 1. Recommendation Rationale Sampling Review

While exhaustive review is infeasible, recommendation rationale outputs are periodically sampled and reviewed for quality, suitability, and regulatory compliance. The recommendation quality monitoring system (L1 rules / L2a rewrite / L2b LLM verification) generates automatic quality metrics, triggering human review on anomaly detection.

### 2. Model Replacement Approval

Champion-Challenger comparison results are confirmed and approved by humans. Even for auto-replacement, a report including replacement rationale, performance comparison, and fairness metrics is generated, with post-review by the operations team.

### 3. Incident Escalation

Auto-detected anomalies (fairness violations, drift, herding) are assessed and acted upon by humans. CRITICAL incidents trigger automatic kill switch activation, followed by human root cause analysis and recovery.

### 4. Fairness Review

Fairness monitoring results are periodically reviewed by humans. Domain experts provide context-aware interpretation of DI/SPD/EOD auto-measurement results, and decide on threshold adjustments or model retraining as needed.

### 5. Opt-out and Complaint Handling

Human reprocessing pathways are automatically activated for customer AI decision refusals and complaints. Auto-counselor routing occurs for 7 reason categories, managed under P1(1h)/P2(4h)/P3(24h) SLA.

#### Human Reprocessing Reason Classification

**P1 (Urgent 1 hour)**

- Compliance violation detected
- Customer failing suitability check
- Kill switch activation situation

**P2 (4 hours) / P3 (24 hours)**

- AI decision refusal (opt-out)
- Low-confidence recommendation results
- Explanation supplementation request
- General complaints

# Automated Governance Report Generation

## Report Framework

Auto-generated on a monthly/quarterly basis, stored in S3, and distributed to the AI Governance Committee.

### 9-Section Structure

| Section | Content | Data Source |
|---|---|---|
| 1 | Fairness summary (DI/SPD/EOD by protected attribute) | FairnessMonitor |
| 2 | Drift summary (PSI statistics for the period) | DriftDetector |
| 3 | Incident summary (CRITICAL/MAJOR/MINOR counts + details) | IncidentReporter |
| 4 | Model change history (training/deployment/rollback) | ExperimentTracker |
| 5 | Kill switch history (activation/deactivation counts) | ComplianceAuditStore |
| 6 | Recommendation quality (L1/L2 rationale quality metrics) | ReasonQualityMonitor |
| 7 | Risk trends (herding trends, risk levels) | HerdingDetector |
| 8 | Audit store summary (7 table record counts) | ComplianceAuditStore |
| 9 | Executive summary (auto-generated narrative) | Combined |

## 36-Item Regulatory Compliance Auto-Check

A quarterly full check is automatically executed via the 36-item regulatory compliance registry.

### Group A (18 Items Implemented)

Model card, training data documentation, safety/trust document
AI disclosure, explainability, opt-out rights
Human review, kill switch, model rollback
Health check, fairness monitoring, suitability constraints, etc.

### GAP Group (18 Items Gap Analysis)

Drift auto-response, recommendation rationale quality verification
SLA tracking, EU AI Act high-risk classification
PIA (Privacy Impact Assessment), etc.

**Check frequency:**

- Daily: Kill switch status, health check
- Weekly: Fairness metrics, explainability
- Quarterly: Full 36-item comprehensive check

## 3-Tier Governance Framework

**Tier 1: Decision — AI Risk Management Committee**

AI utilization policy approval, high-impact AI applicability determination, annual impact assessment approval, critical incident reporting framework

**Tier 2: Execution — AI Operations Team**

Model development and operations, performance monitoring, fairness review, recommendation quality management, incident response

**Tier 3: Verification — Internal Audit & Compliance**

Independent audit, regulatory compliance verification, impact assessment review, external audit response

## Comprehensive Regulatory Mapping

| Regulation | Relevant Articles | Design Reflection |
|---|---|---|
| **AI Basic Act** | Art. 31 (AI content labeling) | AI disclosure + recommendation rationale L1/L2 |
| | Art. 33 (high-impact AI governance) | 36-item registry + governance report |
| | Art. 34 (risk management records) | Audit log immutability + 7 audit tables |
| **Financial Consumer Protection Act** | Art. 19 (explanation duty) | Feature reverse mapping + per-task interpretation |
| **FSS AI RMF** | (1) Legality | 36-item auto-check |
| | (2) Safety/Trust | Kill switch + incident reporting |
| | (4) Reliability | Drift surveillance + auto-retraining |
| | (5) Financial Stability | Fairness DI/SPD/EOD + herding detection |
| **GDPR** | Art. 17 (right to erasure) | 30-day PII retention + encrypted deletion |
| | Art. 22 (automated refusal) | opt_out_audit table |
| | Art. 35 (DPIA) | PIA gap analysis items |
| **PIPA** | Art. 28-2 (pseudonymized data) | Pseudonymization processing record audit |
| | Art. 37-2 (automated decisions) | Opt-out + human reprocessing |

| | | |
|---|---|---|
| **EU AI Act** | Art. 13 (transparency) | Recommendation rationale + model card + audit log |
| | Art. 14 (human oversight) | Kill switch + human reprocessing + per-channel oversight |
| | Art. 15 (accuracy/security) | Drift detection + prompt injection defense |

This document was prepared as of April 2026 and may be updated in accordance with the finalization of the AI Basic Act Enforcement Decree and FSC Integrated AI Guidelines. It is recommended to update this document and report to the AI Risk Management Committee when regulatory changes occur.

# Ops/Audit Agent Integration

All regulatory compliance components documented herein (FairnessMonitor, HerdingDetector, ComplianceChecker, AuditLogger, etc.) are wrapped as tools in the AuditAgent's 48-item checklist for automated inspection.

A 3-agent consensus mechanism (Sonnet×3 independent voting) structurally mitigates hallucination, and minority reports preserve dissenting opinions. Diagnostic history accumulates in a LanceDB case store, serving as "continuous improvement evidence" for regulatory audits.

Core design principle: **"AI analyzes, humans decide"** — agents recommend only; final decisions are made by operators. This structurally satisfies EU AI Act Art.14 (human oversight), Korean FSS AI guidelines (human intervention), and AI Basic Act (kill switch).

Detailed design: Design Document 11 (`docs/design/11_ops_audit_agent.typ`)

## Temporal Fact Store (Added 2026-04)

A core audit evidence requirement is **"reproducing system state at a specific point in time"**. Questions like "At 2026-03-15, when customer A received a recommendation, what were the model version, features, and verdicts?" traditionally require joining across distributed components (AuditLogger, DiagnosticCaseStore, `pipeline_state.json`) — expensive.

We solved this with `TemporalFactStore`, adapted from the Zep/Graphiti pattern. The schema is `(entity, attribute, value, valid_from, valid_to)`, and most audit queries are **single-entity point-in-time reconstructions** resolvable via native LanceDB filters.

| Property | Implementation |
|---|---|
| No deletion | `expire_fact()` sets `valid_to` only, originals preserved |
| Backend | Shares LanceDB instance with `DiagnosticCaseStore` (zero new deps) |
| Z-suffix compat | Normalizes diverse timestamp formats from external callers |
| Query API | `snapshot_at()`, `get_timeline()`, `expire_fact()` |

This satisfies EU AI Act Art.12 (record-keeping), Korean FSS AI guidelines (audit trail), and AI Basic Act temporal evidence requirements via a single store.